
RAPPORT D'EXPLOITATION TECHNIQUE

Nom du Projet : **Pentest-Checkpoint**
Auteur : **Aurian-P**
Organisation : **Checkpoint**
Cible : **checkpoint.htb (10.129.107.12)**
Type d'évaluation : Pentest "**Boîte Grise**" (grey box) interne
Autentifiants de départ : **alex.turner / Checkpoint2024!**
Date du test : **25/08/2026**
Version du document : **1**

Synthèse Exécutive

L'évaluation a permis la compromission totale du système cible avec l'obtention des privilèges d'administration maximaux (checkpoint\administrator).

La chaîne d'exploitation s'est articulée selon les étapes suivantes :

1. Premier mouvement latéral obtenu suite à la récupération d'un compte utilisateur présent dans la corbeille (mark.davies)
2. Second mouvement latéral : Exploitation d'un share smb qui exécute des extensions vsix de manière récurrente, et qui est disponible en écriture pour notre utilisateur. Obtention d'un shell sur le compte ryan.brooks, récupération du flag user.txt.
3. Privilège escalation : L'utilisateur ryan.brooks ayant la permission WRITE sur le compte de service svc_deploy, utilisation de la technique BadSuccessor pour obtenir l'accès de svc_deploy aux différents shares.
4. Récupération des snapshots présents dans le share VMBackups, et capture du hash NTLM du compte administrator. Obtention d'un shell avec les privilèges maximaux via winrm. Récupération du flag root.txt.

Sévérité	Nombre
Critique	0
Elevée	4
Moyenne / Faible	0

Cartographie des Services

Un balayage de ports avec Nmap a révélé les services exposés suivants :

Port/Protocole	Service	Version	Information supplémentaire
53/TCP	DNS	Simple DNS Plus	/
88/TCP	kerberos	Microsoft Windows Kerberos	/
123/UDP	NTP	NTP v3	/
135/TCP	msrpc	Microsoft Windows RPC	/
139/TCP	Netbios-ssn	Microsoft Windows netbios-ssn	/
389/TCP	ldap	Microsoft Windows Active Directory LDAP	Domaine : checkpoint.htb0
445/TCP	microsoft-ds	/	/
464/TCP	kpasswd5	/	/
593/TCP	ncacn_http	Microsoft Windows RPC over HTTP 1.0	/
636/TCP	ldapssl	/	/
3268/TCP	ldap	Microsoft Windows Active Directory LDAP	/
3269/TCP	globalcatLDAPssl	/	/
5985/TCP	http	Microsoft HTTPAPI httpd 2.0	/
9389/TCP	mc-nmf	.NET Message Framing	/
49664/TCP	msrpc	Microsoft Windows RPC	/
49670/TCP	msrpc	Microsoft Windows RPC	/
49673/TCP	msrpc	Microsoft Windows RPC	/
49679/TCP	msrpc	Microsoft Windows RPC	/
49680/TCP	ncacn_http	Misrosoft Windows RPC over HTTP 1.0	/
49683/TCP	msrpc	Microsoft Windows RPC	/
49710/TCP	msrpc	Microsoft Windows RPC	/
49718/TCP	msrpc	Microsoft Windows RPC	/

Fiches détaillées des vulnérabilités

VULN -01: Restauration d'objet depuis la corbeille Active Directory

Sévérité :

Elevée (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-269 Improper Privilege Management (Mauvaise gestion des privilèges)

Composant : Permission du compte alex.turner :

distinguishedName:CN=MarkDavies\0ADEL:2217e877-e2a2-47d7-91d4-99ede36f367e,CN=Deleted Objects,DC=checkpoint,DC=htb permission: WRITE

Description :

L'utilisateur alex.turner a les droits WRITE sur le compte mark.davies, qui se situe initialement dans la corbeille (0ADEL). Cette permission permet à l'utilisateur alex.turner de restaurer le compte mark.davies, ainsi que de modifier son mot de passe utilisateur.

Ainsi, un attaquant peut ensuite s'authentifier en tant qu'utilisateur mark.davies et récupérer ses droits ainsi que ses accès.

Cet utilisateur dispose notamment de droit WRITE sur le share SMB DevDrop.

Preuve de concept :

Utilisation de l'outil BloddyAD pour lister les objets auxquels le compte alex.turner a accès :

→ L'objet utilisateur mark.davies, présent dans la corbeille est accessible en écriture par le compte de départ alex.turner.

Restauration du compte mark.davies :

→ L'utilisateur a bien été restauré

Vérification de l'accès au compte mark.davies via SMB :

→ On a bien accès au compte mark.davies, et on a accès à shares, notamment le droit d'écriture sur le share DevDrop.

Impact :

L'exploitation de cette vulnérabilité peut permettre à un attaquant de restaurer puis de se déplacer latéralement sur un autre compte utilisateur, récupérant l'accès WRITE sur le share smb DevDrop.

Recommandations / Remédiation :

Implémenter un contrôle d'accès basé sur les rôles, suivant le principe du moindre privilège, seuls les comptes d'administration devraient avoir accès aux fonctionnalités de la corbeille.

Sécuriser le processus de restauration, qui devrait aussi être réservé aux comptes administrateurs.

VULN-02 : Exécution de code via partage SMB et extensions VS Code

Sévérité :

Elevée (CVSS v3.1 : 8,0 | CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H)

CWE : CWE-732 : Incorrect Permission Assignment for Critical Resource (Attribution incorrecte de permissions pour une ressource critique)

Composant : le share smb DevDrop avec la description "VS Code extensions share for approved .vsix packages compatible with VS Code engine 1.118.0"

Description :

La permission en écriture de l'utilisateur mark.davies sur ce share smb lui permet de déposer des fichiers. L'exécution automatique des fichiers .vsix avec les configuration adéquates permet à un attaquant d'obtenir un reverse shell sur l'utilisateur ryan.brooks.

Preuve de concept :

Création du fichier de configuration package.json, ainsi que du fichier code [extension.js](#) dans un dossier /extension.

→ Avec ces fichiers, on peut maintenant créer le vsix.

Création du fichier test.vsix avec zip :

→ On a le .vsix, on va pouvoir le déposer dans le share smb :

Dépôt du fichier test.vsix sur le share smb :

Exécution automatique du fichier déposé, puis obtention d'un reverse shell sur l'utilisateur ryan.brooks.

Impact :

L'injection de fichier malveillant dans le share smb DevDrop a permis l'obtention d'un reverse shell sur l'utilisateur ryan.brooks, donnant l'accès à ses droits et ses accès. Récupération du flag user.txt.

Recommandations / Remédiation :

Appliquer le principe du moindre privilège sur les shares SMB, un utilisateur standard ne doit avoir les droits d'en lecture seule.

Sécuriser le mécanisme de chargement des extensions vsix, désactiver l'exécution automatique.

VULN-03 : Abus du mécanisme de dMSA (BadSuccessor - CVE-2025-53779)

Sévérité :

Elevé (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-269 : Improper Privilege Management (gestion incorrecte des privilèges)

Composant : distinguishedName:CN=svc_deploy,OU=ServiceAccounts,DC=checkpoint,DC=htb
/ permission: WRITE

Description :

La vulnérabilité CVE-2025-53779 est une faille majeure liée à la fonctionnalité dMSA (delegated Managed Service Accounts) introduite dans Windows Server 2025.

Dans notre scénario, la récupération du ticket Kerberos de l'utilisateur ryan.brooks via l'outil rubeus.exe téléchargé sur la cible, a permis l'énumération des accès aux objets pour cet utilisateur. Sa permission write sur le service svc_deploy, couplée à la version du contrôleur de domaine (Windows Server 2025), remplissent les conditions pour l'exploitation de BadSuccessor.

Un attaquant peut créer un objet DMSA avec l'identité de ryan.brooks mais dans le contexte du service svc_deploy. Ainsi ce nouvel objet aura les mêmes droits et accès que svc_deploy.

Preuve de concept :

Téléchargement de l'outil rubeus.exe dans le dossier /windows/Temp :

Utilisation de l'outil rubeus pour récupérer le hash du compte ryan.brooks :

Transformation du ticket en .ccache, puis utilisation de l'outil bloodyAD pour énumérer les accès du compte ryan.brooks :

--> L'utilisateur ryan.brooks a les accès WRITE au service svc_deploy.

Vérification de la version du contrôleur de domaine (pour utiliser badsuccessore il faut que le contrôleur de domaine soit en Windows server 2025):

→ Les conditions sont réunies pour pouvoir exploiter la vulnérabilité BadSuccessor.

Création d'un objet DMSA par l'utilisateur ryan.brooks, mais sous les conditions de sv_deploy.

--> Obtention d'un ticket avec les accès svc_deploy.

Utilisation du nouveau ticket, puis énumération des shares disponibles :

--> On a accès à la lecture du share VMBackups

Impact :

L'exploitation de la CVE-2025-53779 a permis à l'utilisateur ryan.brooks de créer un objet avec les accès du compte système : svc_deploy. Ce compte a accès à la lecture d'un share indisponible jusqu'alors : VMBackups.

Recommandations / Remédiation :

Mettre à jour les contrôleurs de domaines Windows Server 2025 pour corriger la faille de logique Kerberos liée à la CVE-2025-53779.

Auditer et restreindre les permissions de modifications sur les compte de service, notamment le compte svc_deploy.

Bloquer le droit de création/modification d'objets dMSA pour les utilisateurs non-administrateurs.

VULN-04 : Exposition de snapshots de machines virtuelles contenant des secrets

Sévérité :

Elevée (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-522 : Identifiants insuffisamment protégés

Composant : Snapshot présents dans le share VMBackups\NightlyBackup_2024-11-01\memory forensics\windows Server 2019-Snapshot1.vmsem

Description :

L'accès READ au share VMBackups a permis le téléchargement de snapshots.

Ces snapshot contiennent toutes les informations nécessaires à l'obtention du hash du compte administrator. Un attaquant qui récupère ces snapshot peut obtenir les hashes NTLM de tous les comptes connectés lors de la prise de ces snapshots.

Permettant ensuite d'utiliser ces hashes pour se connecter directement sur le compte administrator et obtenir une compromission totale de la machine.

Preuve de concept :

Lecture du dossier VMBackups via l'outil Impacket.

→ De nombreux snapshots sont disponibles.

Utilisation d'un script python pour récupérer les snapshot :

Récupération des hashes présents sur les snapshots récupérés avec Volatility3 :

Validation de l'élévation de privilèges :

Impact :

La récupération des snapshots présents dans le share VMBackups a permis le dump des hashes des comptes connectés lors du snapshot.

La récupération du hash NTLM administrator a permis un accès winrm direct sur la cible en tant qu'administrator, ce qui correspond à une compromission totale de la cible.

Recommandations / Remédiation :

Sécuriser et Isoler les données de sauvegarde : Chiffrement, cloisonnement réseau.

Durcir l'authentification et les accès distants : désactiver LM/NTLM lorsque c'est possible.